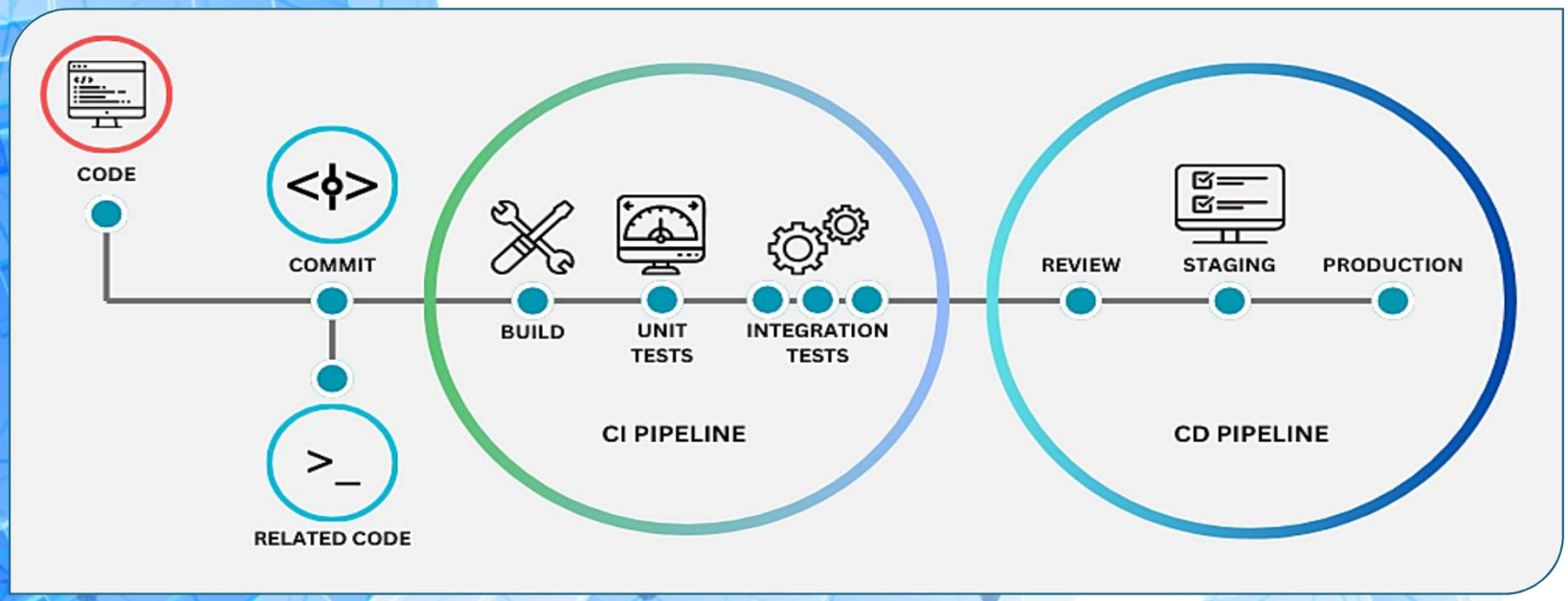


DevSecOps

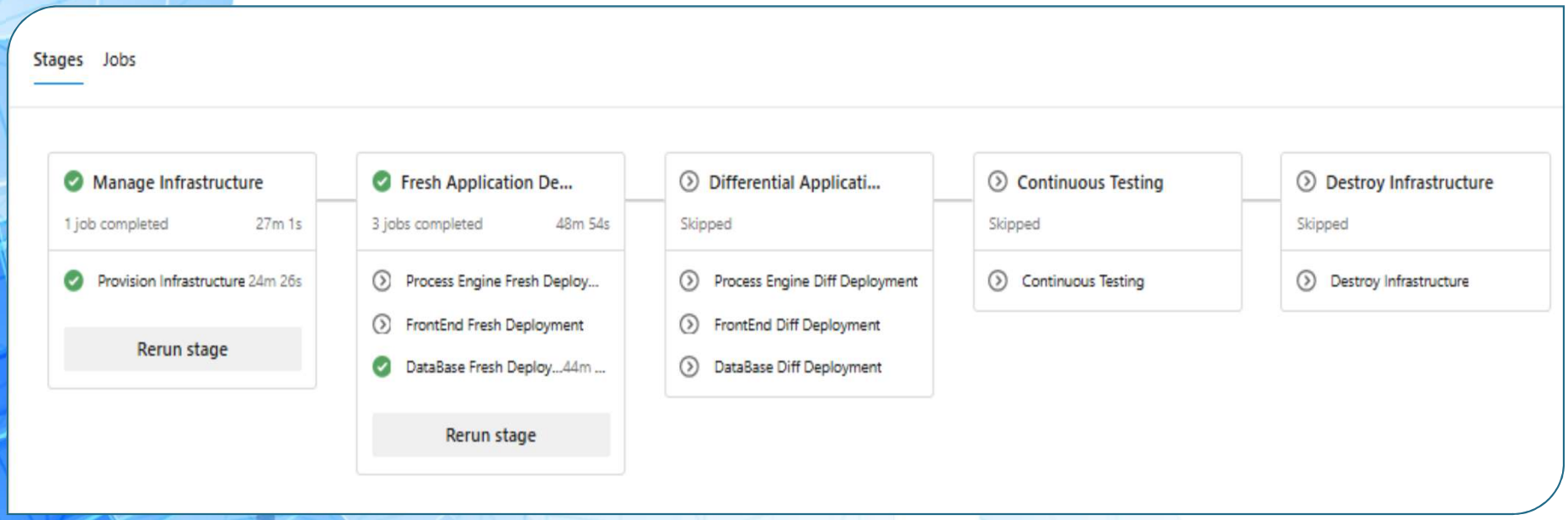
DevOps

DevOps is a set of practices and cultural changes — supported by automation tools and Lean processes — that creates an automated software delivery pipeline, enabling organizations to deliver better-quality services and applications faster."

Goal: Shorten the SDLC while delivering high-quality software.

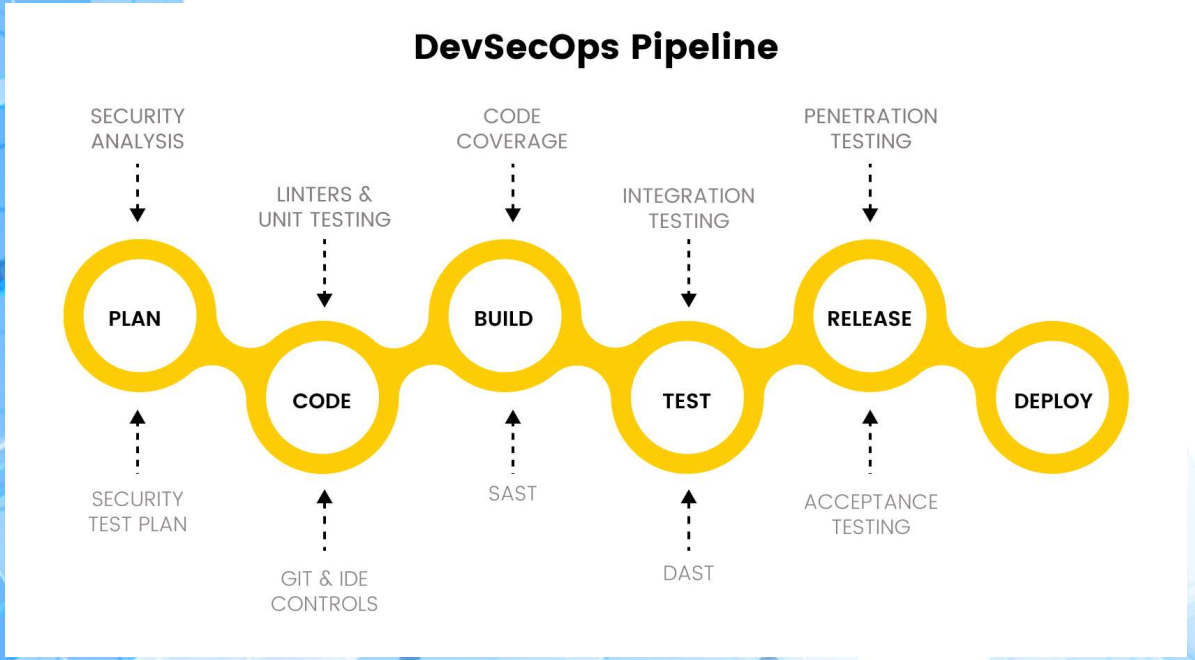


DevOps Cont.

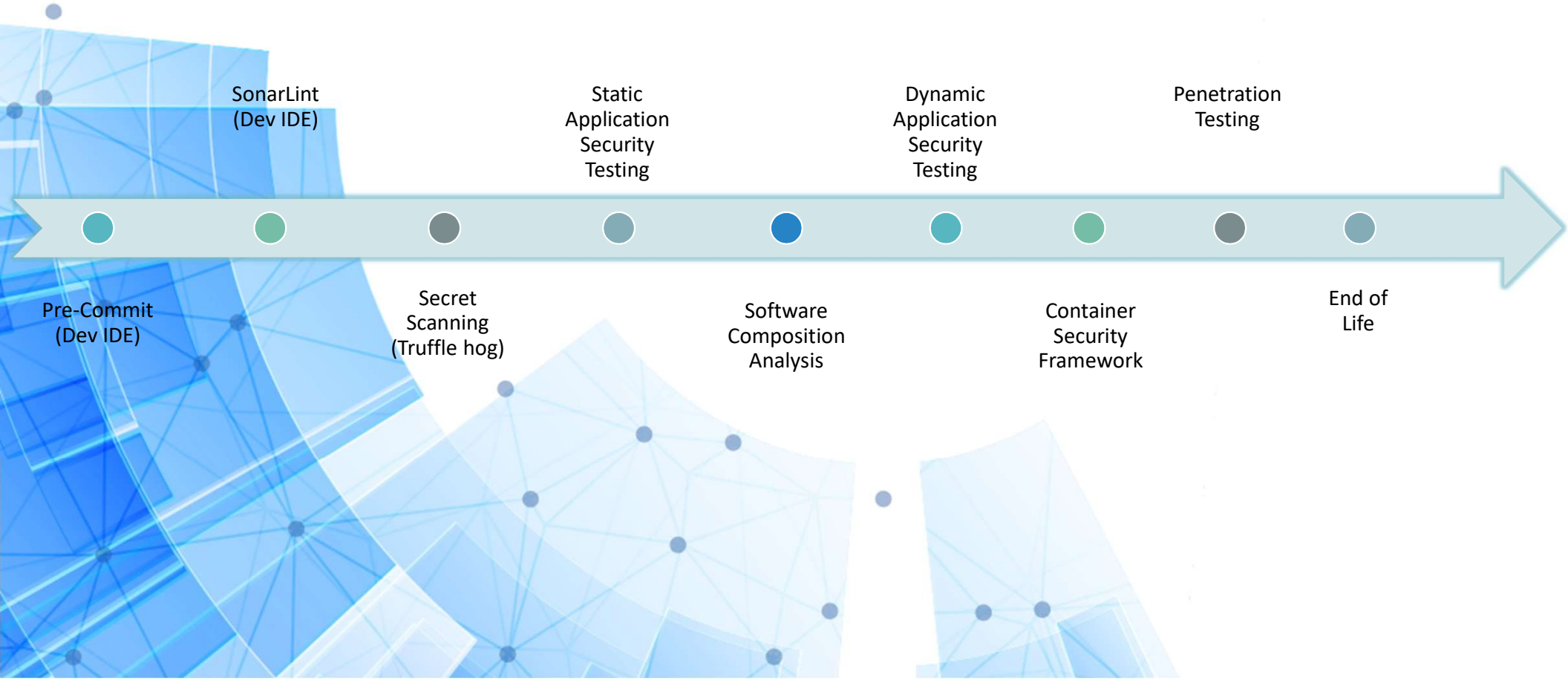

Stages
Jobs
Manage Infrastructure
1 job completed
27m 1s
Provision Infrastructure 24m 26s
Rerun stage
Fresh Application De...
3 jobs completed
48m 54s
Process Engine Fresh Deploy...
FrontEnd Fresh Deployment
DataBase Fresh Deploy...44m ...
Rerun stage
Differential Applicati...
Skipped
Process Engine Diff Deployment
FrontEnd Diff Deployment
DataBase Diff Deployment
Continuous Testing
Skipped
Continuous Testing
Destroy Infrastructure
Skipped
Destroy Infrastructure

DevSecOps

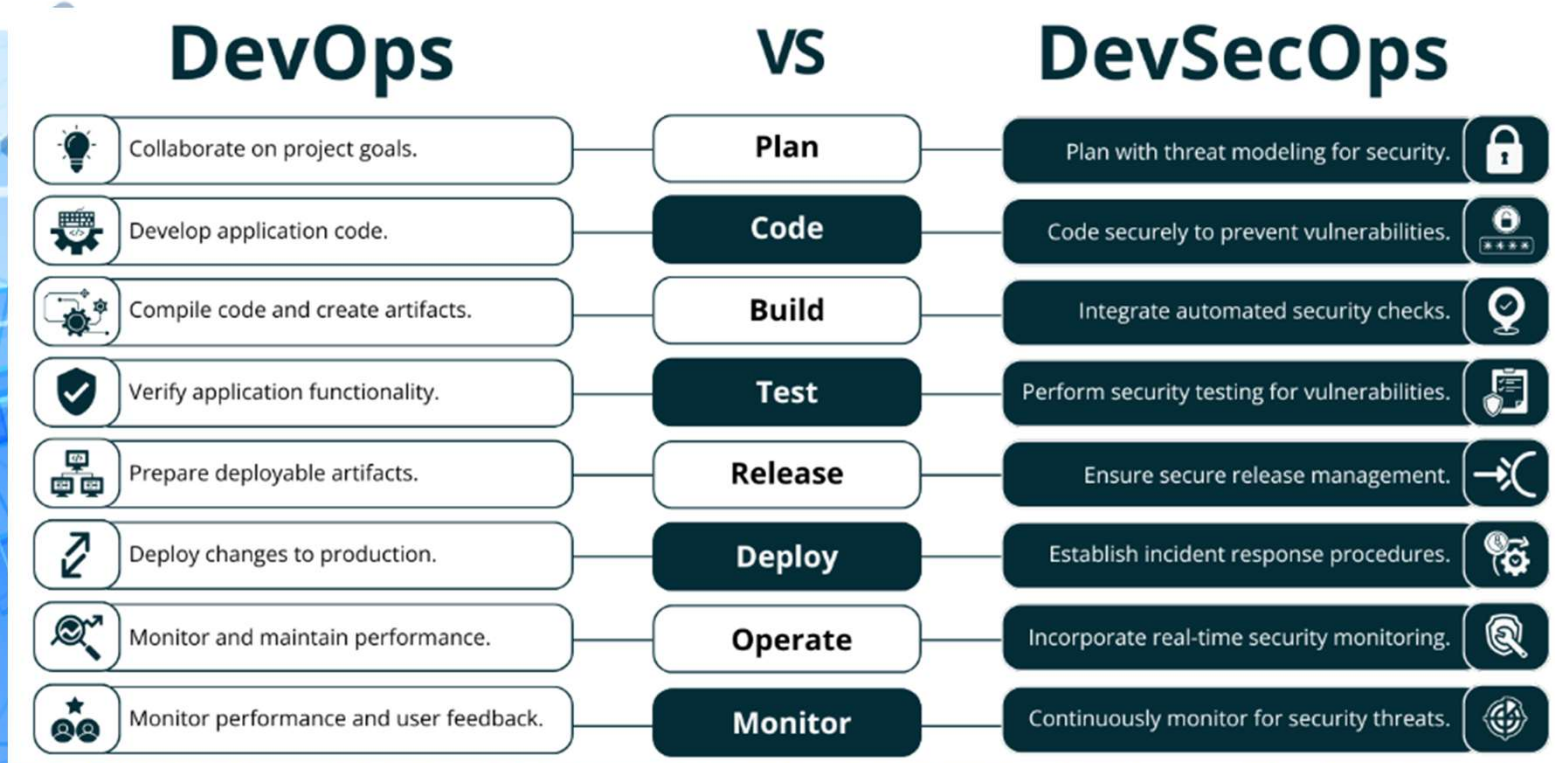
DevSecOps integrates security practices within DevOps.
Goal: *Secure applications throughout the software development lifecycle (SDLC).*
Benefits: *Early vulnerability detection, automated security checks, compliance enforcement.*



DevSecOps

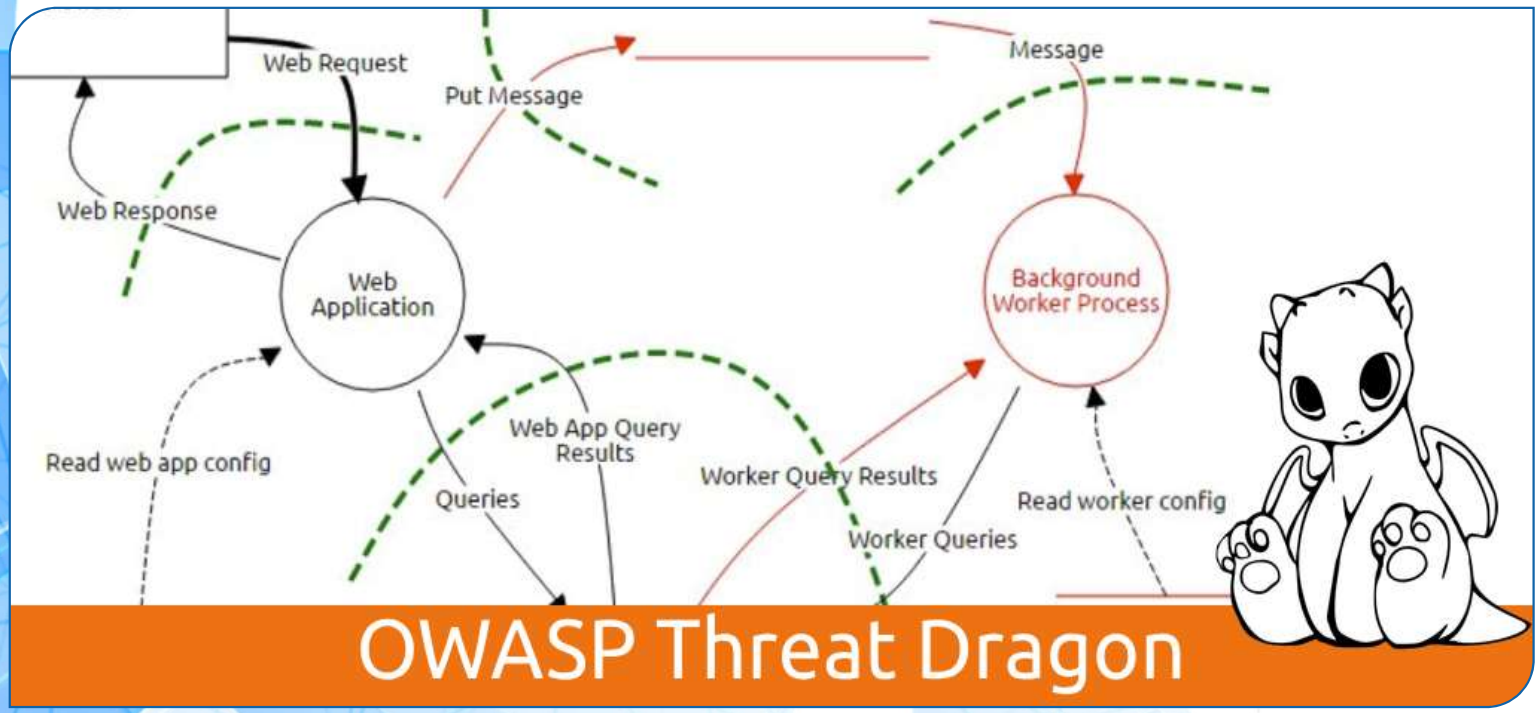

Pre-Commit
(Dev IDE)
SonarLint
(Dev IDE)
Secret
Scanning
(Truffle hog)
Static
Application
Security
Testing
Software
Composition
Analysis
Dynamic
Application
Security
Testing
Container
Security
Framework
Penetration
Testing
End of
Life

DevOps VS DevSecOps



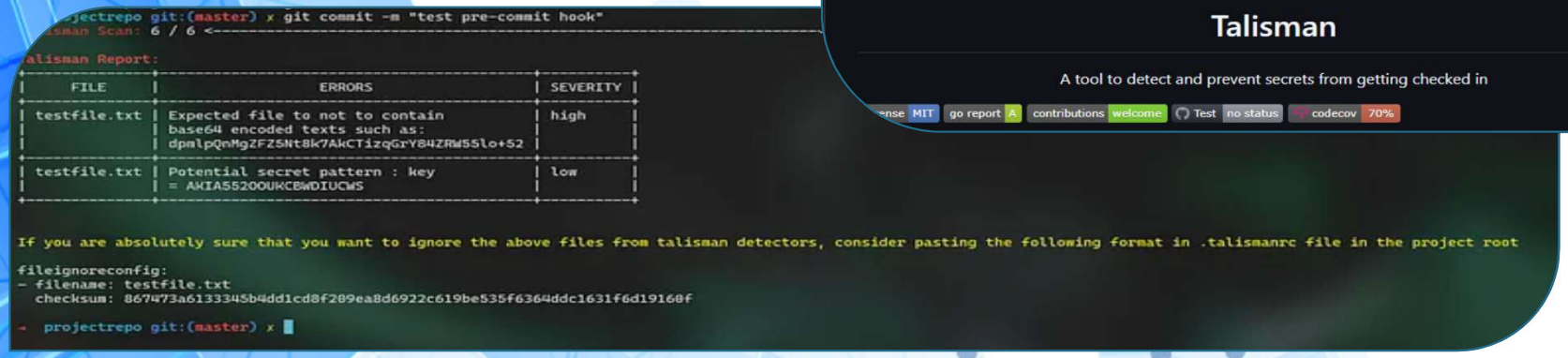
Threat Modeling in DevSecOps

Tools: OWASP Threat Dragon.
Purpose: Identifies and analyzes potential security threats in applications.
Benefits: Early detection of vulnerabilities, improved risk assessment.



Pre-Commit Hook (Dev IDE)

Tools: *Talisman*
Purpose: *Automated Security assessments to commits done by developers.*
Benefits: *Timely identification and elimination of potential secrets pushed into the source code.*



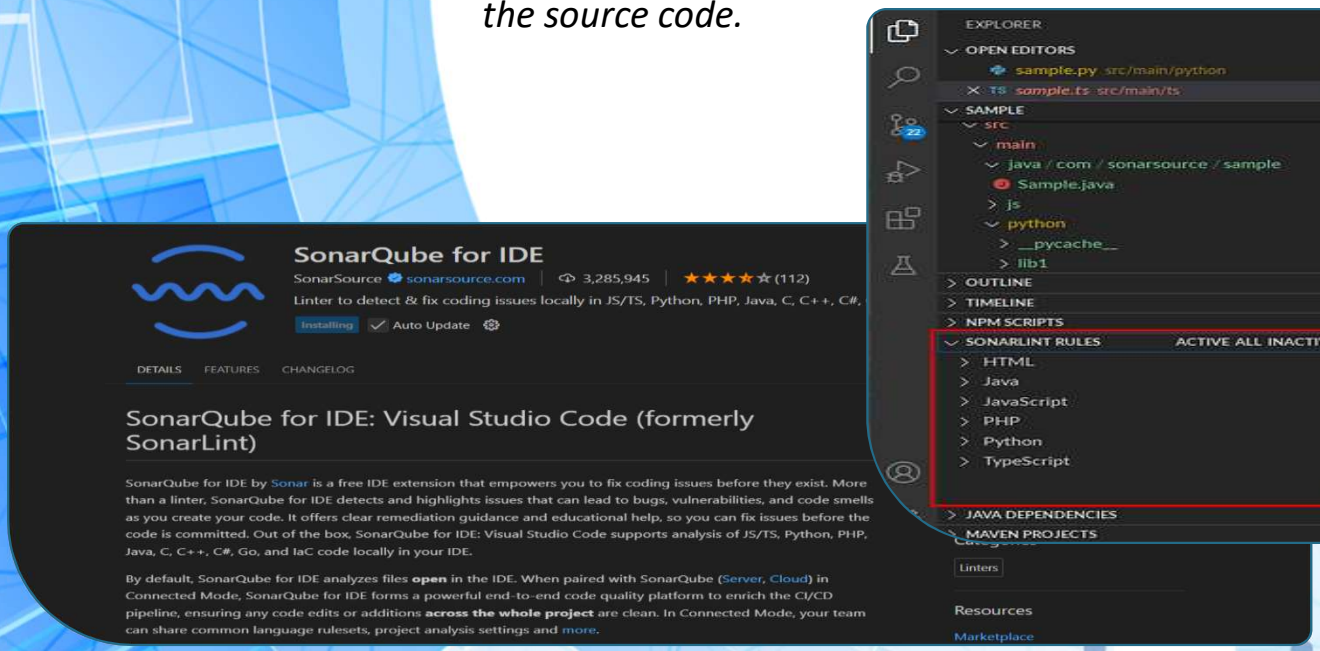


Sonarlint (Dev IDE)

Tools: **SonarQube for IDE**

Purpose: *Automated Security assessments to source code done by developers.*

Benefits: *Timely identification and elimination of potential secrets, vulnerabilities, code smells, hotspots etc. pushed into the source code.*

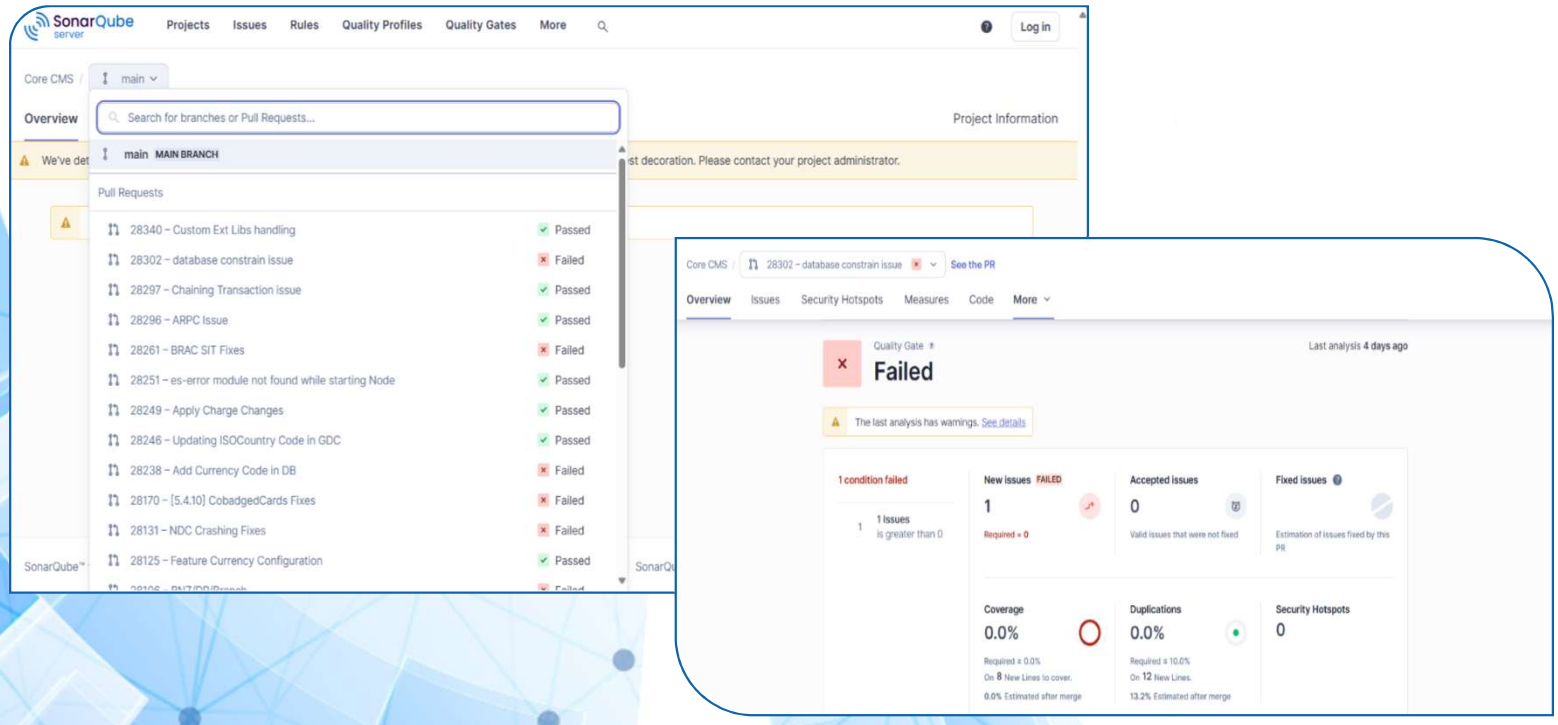


Static Application Security Testing (SAST)

Tool: **SonarQube**

Purpose: *Detects security vulnerabilities in source code.*

Benefits: *Early detection, integration with CI/CD pipelines for incoming PR/Source.*



Software Composition Analysis (SCA)

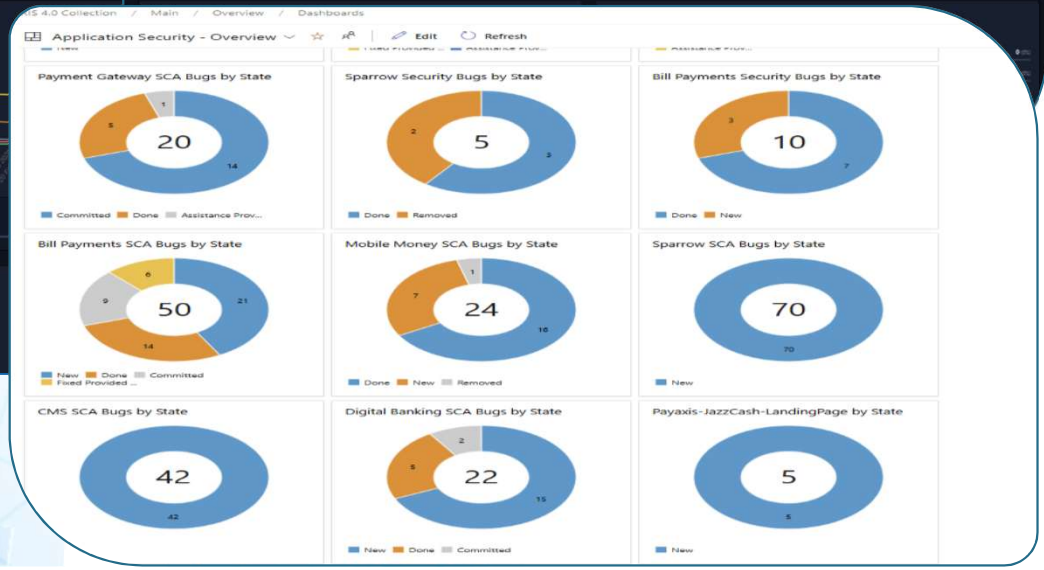
Tool: **Dependency-Track**

Purpose: *Identifies vulnerabilities in open-source dependencies.*

Benefits: *Helps manage risk in third-party libraries.*





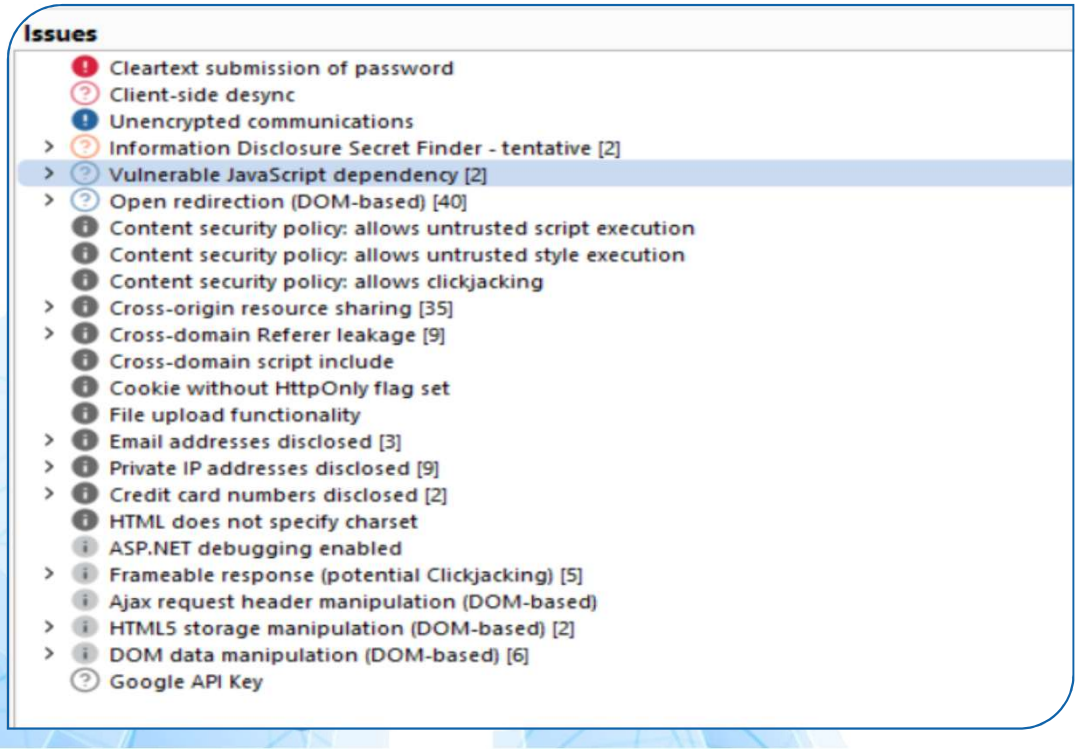


Dynamic Application Security Testing (DAST)

Tool: *Burp Suite Professional (Vulnerability Assesment & Active/Passive Scans)*

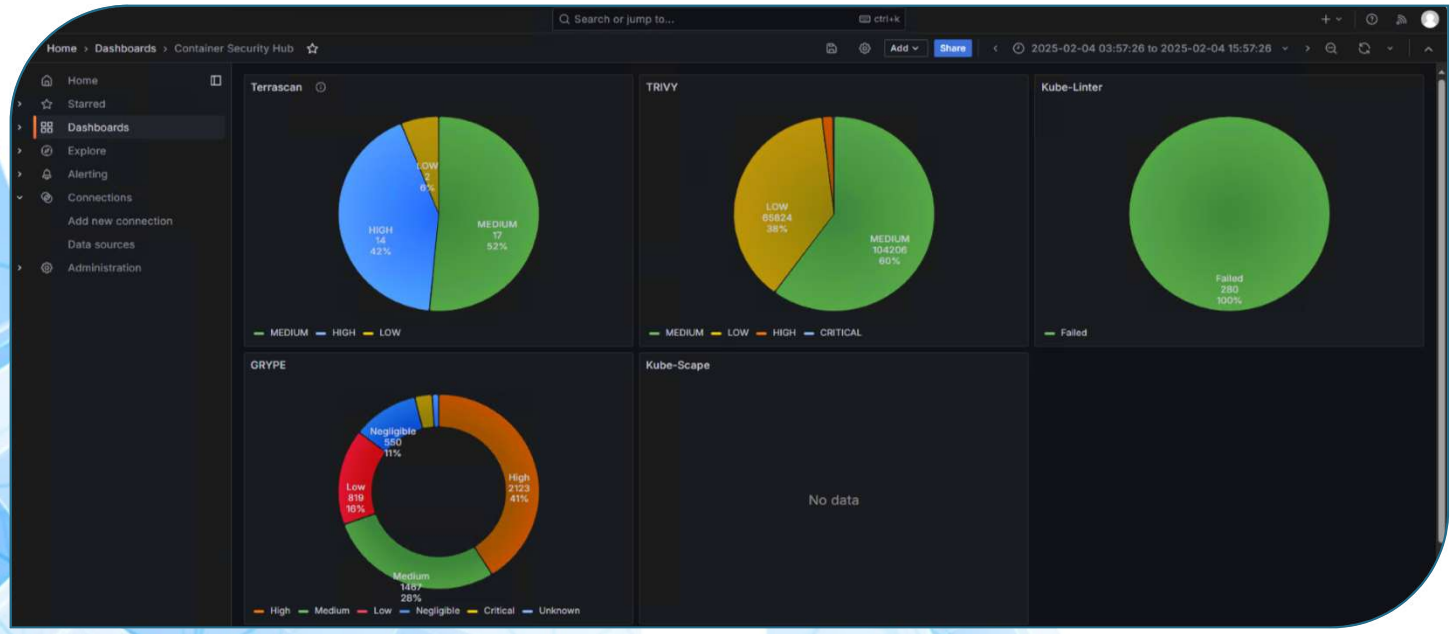
Purpose: *Identifies runtime vulnerabilities in web applications.*

Benefits: *Detects security flaws in a running application.*



Container Security Framework (CSF)

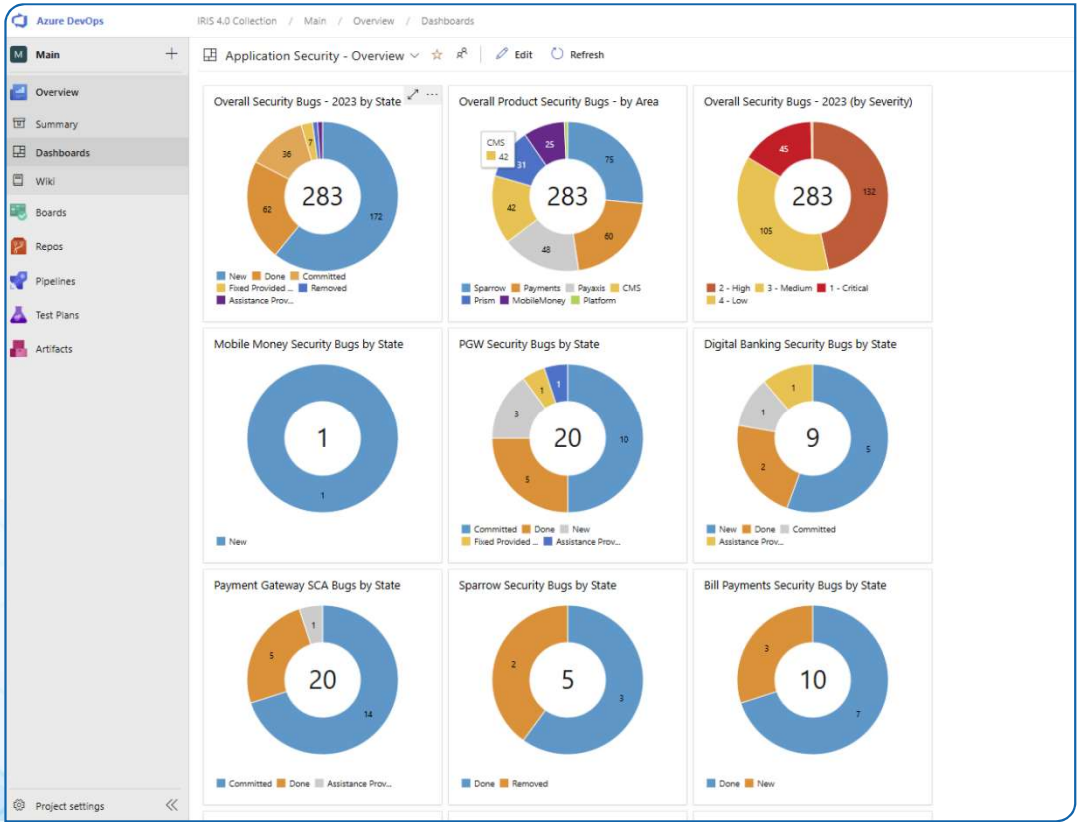
Tools: **Image and container scanning tools.**
Grype, Trivy, Kube-Linter, Kube-Bench, Kube-Scape.
Purpose: *Ensures security of containerized applications.*
Benefits: *Detects vulnerabilities in container images before deployment.*



Penetration Testing (PT)

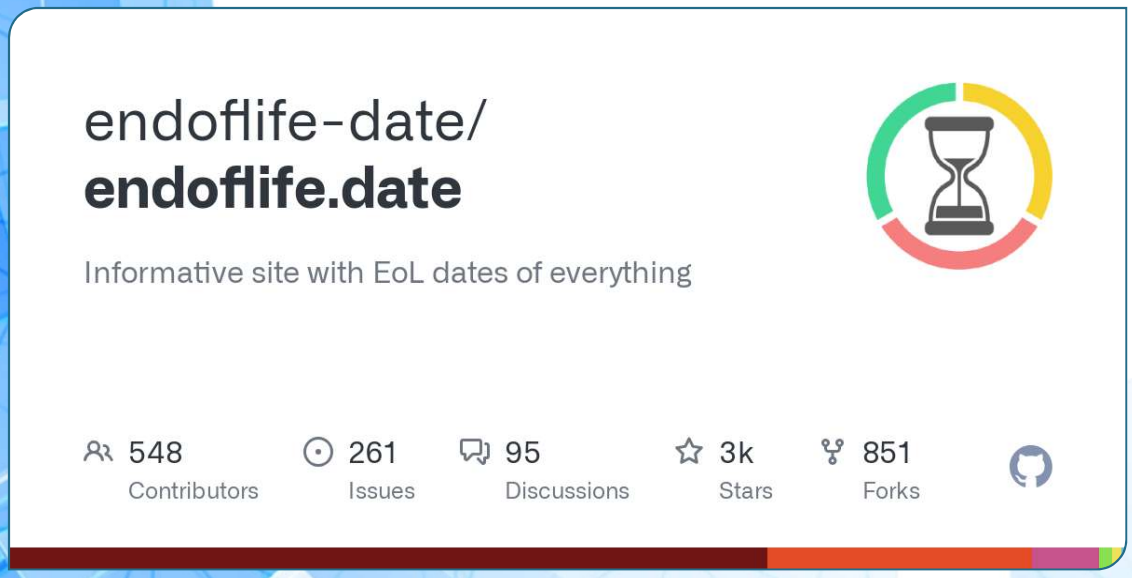
Tools: **Burp Suite Professional**
Purpose: *Manual security assessments to identify weaknesses.*
Benefits: *Identifies business logic vulnerabilities that automated tools may miss.*

Automated Security Testing:
Automation of Repeated Similar Security Test Cases.
•Automation of Repeated SimilarLogical Security Test Cases.



End of Life (EOL)

Dedication: Ensuring secure and resilient software by proactively addressing risks associated with End of Life (EOL) components.
Goal: Maintain security, compliance, and stability by identifying, replacing, and mitigating risks from deprecated dependencies.





Thank You !